LEZIONE 1

Difendere dall'interno

ITS CyberSecurity - Jesi (AN) 2026/2027

Corso VAPT - Defensive Side

prof. Luca Ferroni

1. trova

2. correggi

3. verifica

il lavoro di chi difende

Tre corsi, un percorso

In quest'ordine



Prima impariamo a difendere: poi ad attaccare quello che sappiamo difendere.

Cosa vedremo

I moduli ITS del Defensive Side

- **Vulnerability Assessment interno**
  cercare le debolezze note nei sistemi della propria rete
- **Dynamic Analysis**
  provare un'applicazione mentre gira, come farebbe un utente
- **Software di terze parti**
  librerie e immagini Docker: falle che non hai scritto tu
- **Data Loss Prevention**
  impedire che i dati sensibili escano dall'azienda
- **Insider Threat**
  la minaccia da dentro: dipendenti, account rubati
- **Active Defense**
  rilevare e bloccare in automatico, non solo aspettare
- **Cyber Deception**
  esche e trappole (honeypot) per scoprire chi entra
- **Ripasso ed esame**
  esercitazioni su tutto il corso

Sempre in laboratorio, sempre con i log sotto gli occhi: Loki e Grafana li conoscete già.

Parte 1

Valutare la sicurezza

Vulnerability Assessment e Penetration Test

Vulnerabilità, minaccia, rischio

Tre parole da non confondere

Vulnerabilità
una debolezza

Minaccia
chi o cosa la può sfruttare

Rischio
probabilità × impatto

Esempio

Grafana raggiungibile da Internet con admin/admin.

Vulnerabilità: la password di default. Minaccia: i bot che provano admin/admin.

Rischio: alto, perché è probabile e chi entra legge tutti i log.

CVE e CVSS

Un nome e un voto per ogni vulnerabilità nota

CVE-2021-44228

Log4Shell: una libreria Java usata ovunque

CVE = il nome, uguale per tutti

Common Vulnerabilities and Exposures

CVSS = il voto da 0 a 10

Common Vulnerability Scoring System

Log4Shell: 10.0

Bassa	0.1 – 3.9
Media	4.0 – 6.9
Alta	7.0 – 8.9
Critica	9.0 – 10.0

Il voto dice quanto è grave in generale, non quanto lo è per te.

Vulnerability Assessment

VA

Che cosa è vulnerabile?

- In largo: più sistemi possibile.
- Soprattutto automatico: uno scanner, poi la verifica.
- Non si sfruttano le vulnerabilità: si elencano.
- Risultato: un elenco con voto e rimedio.

Penetration Test

PT

Che cosa può fare un attaccante?

- In profondità: un percorso fino all'obiettivo.
- Soprattutto a mano, con competenze alte.
- Si sfruttano le vulnerabilità, entro regole precise.
- Risultato: il racconto dell'attacco, con le prove.

VA e PT a confronto

	VA	PT
Domanda	che cosa è vulnerabile?	che cosa può fare?
Come	scanner + verifica	a mano, con exploit
Rischio per i sistemi	basso	più alto
Falsi positivi	frequenti	rari
Quanto spesso	periodico, continuo	una volta l'anno
Costo	basso	alto

Quanto sa chi fa il test?

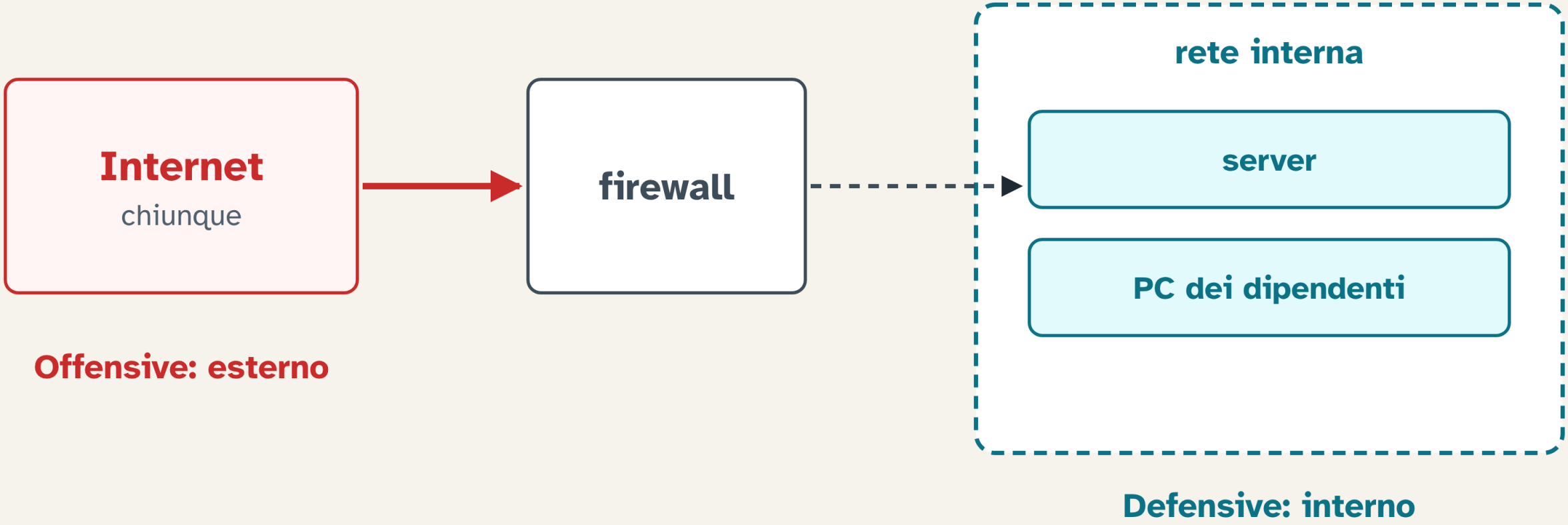
Tre modi di fare un PT

Black box	**Grey box**	**White box**
non sa niente	sa qualcosa	sa tutto
come un estraneo	come un utente normale	documenti e codice

Meno sa, più assomiglia a un attacco vero. Più sa, più trova nello stesso tempo.

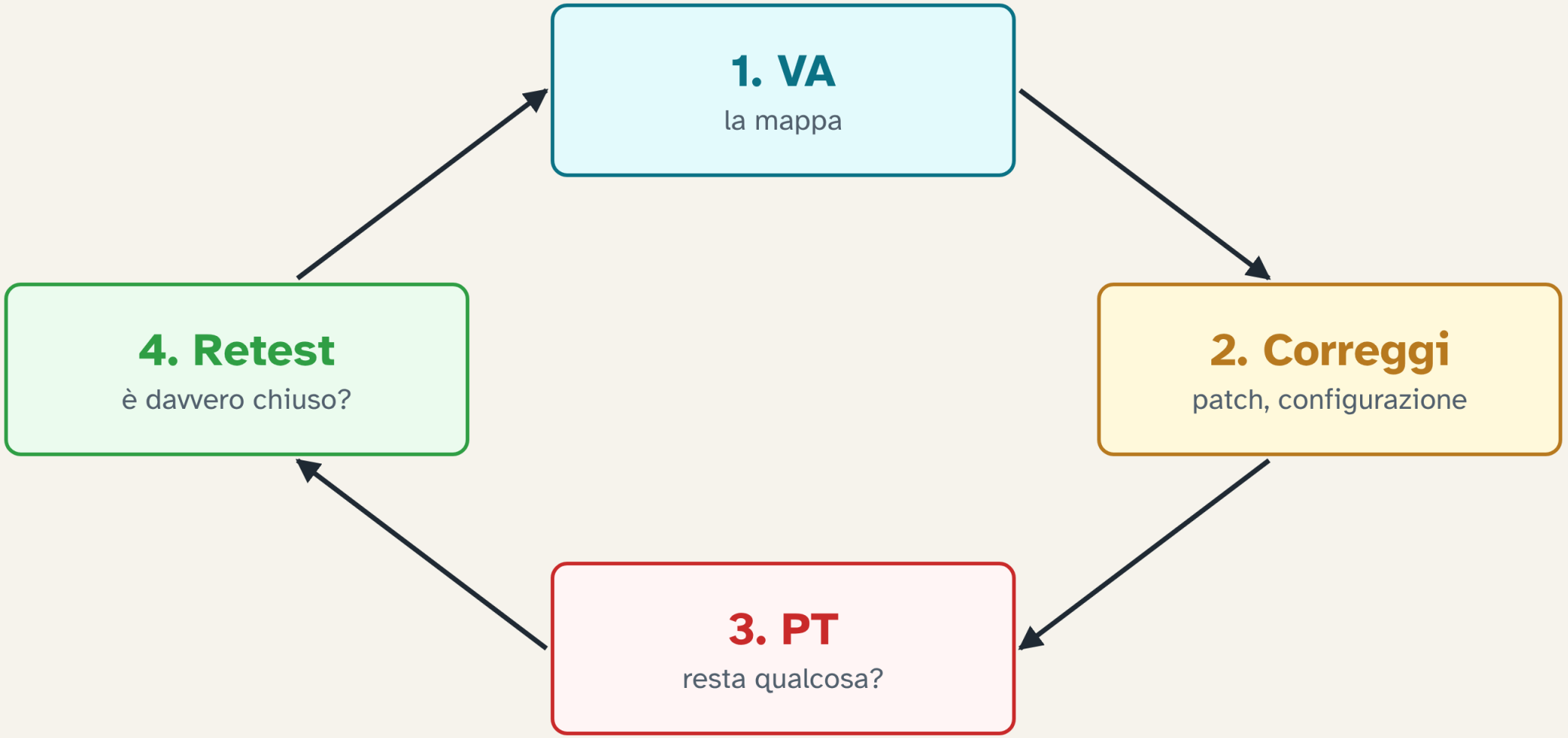
Da dove guardi?

Interno ed esterno



Dall'interno si vede molto di più: anche quello che il firewall nasconde.

Un ciclo, non un evento



Gli errori più comuni

Una scansione automatica venduta come PT.

Ha la forma di un report, ma nessuno ha provato davvero.

Una VA che finisce in un cassetto.

Senza correzione e retest l'elenco serve solo a dire "lo sapevamo".

Parte 2

Le regole

Prima di toccare un sistema

Senza permesso è un reato

Art. 615-ter del Codice penale: accesso abusivo a un sistema informatico

Autorizzazione scritta

di chi ha il potere di darla, prima di iniziare

- Entrare in un sistema senza permesso è accesso abusivo.
- Anche solo scansionare reti altrui crea guai: denunce, contratti violati.
- "Volevo solo vedere" non è una difesa.

Le regole d'ingaggio

Cosa si scrive nell'autorizzazione

1. **Perimetro: quali indirizzi e quali no**
2. **Quando: giorni e orari**
3. **Cosa è vietato: per esempio fermare i servizi**
4. **Chi chiamare se qualcosa si rompe**
5. **Cosa fare se trovi dati personali**

In questo corso: si scansiona solo il laboratorio.

Parte 3

NIS2

Cosa chiede la legge a chi difende

Perché si chiama NIS

Network and Information Systems: reti e sistemi informativi

Proteggere reti e sistemi informativi è la cybersecurity.

NIS · 2016
in Italia D.Lgs. 65/2018

→ **più settori**

NIS2 · 2022
in Italia D.Lgs. 138/2024, dal 16/10/2024

Chi non rispetta gli obblighi paga

soggetti essenziali: fino a 10 milioni di euro o al 2% del fatturato mondiale

soggetti importanti: fino a 7 milioni di euro o all'1,4% del fatturato mondiale

vale l'importo più alto

E ne rispondono i vertici dell'azienda: approvano le misure e devono formarsi.

NIS2 in una slide



Chi: i soggetti essenziali e importanti (energia, sanità, trasporti, digitale…).

Due obblighi per noi:

misure di sicurezza: art. 24

notifica degli incidenti: art. 25

Nella direttiva sono gli articoli 21 e 23.

Le dieci misure minime

Art. 24 D.Lgs. 138/2024 (art. 21 NIS2)

a) analisi dei rischi

b) gestione degli incidenti

c) continuità e backup

d) catena di fornitura

e) **gestione delle vulnerabilità**

f) **verificare che le misure funzionino**

g) igiene informatica e formazione

h) crittografia

i) personale, accessi, asset

l) autenticazione a più fattori

e) e f) sono il cuore del VAPT: trovare le vulnerabilità e verificare le difese.

Notificare un incidente grave

Art. 25 D.Lgs. 138/2024 (art. 23 NIS2): al CSIRT Italia



Significativo = grave disservizio o perdite, per l'azienda o per altri.

Le 24 ore partono quando te ne accorgi



Quanto è lungo il "giorno ?" dipende da voi:

log centralizzati, metriche, allarmi.

Quello che avete costruito nel corso di Logging serve esattamente a questo.

VA e PT sono obbligatori?

La risposta onesta

La NIS2 non li nomina negli articoli.

Ma sono il modo pratico per rispettare le misure e) ed f).

E l'ACN può chiederli. *Agenzia per la Cybersicurezza Nazionale*

- Può imporre audit e scansioni di sicurezza (art. 35).
- Li fanno organismi indipendenti, a spese dell'azienda (art. 34).

Parte 4

VA primordiale

Il nostro server visto da fuori, dal lato blue team

Cosa espone il nostro server?

VA primordiale · blue team

its.fabersoft.net: lo stack del corso di Logging

Grafana
:3000 con login

Loki
:3100 senza login

Prometheus
:9090 senza login

La domanda del blue team:

chi riesce a raggiungere queste porte?

Si scansiona un server nostro: l'autorizzazione ce la diamo da soli.

Bussare alle porte: nmap

VA primordiale · blue team

```
$ nmap -Pn -p 3000,3100,9090 its.fabersoft.net
```

```
PORT      STATE
3000/tcp    open
3100/tcp    open
9090/tcp    open
```

-Pn non provare il ping prima

-p solo queste porte

open = qualcuno risponde,
da qualsiasi punto di Internet.

Output semplificato: quello vero lo leggiamo insieme in aula.

Open: e allora?

VA primordiale · blue team

```
$ curl http://its.fabersoft.net:3100/loki/api/v1/labels
{"status":"success","data":["host","job"]}
```

Risposta di esempio: le etichette dei log di tutta la classe.

- Da Loki chiunque può leggere i log di tutti.
- Da Prometheus chiunque vede le metriche di ogni PC.
- E può anche spedire log falsi a Loki.

Chiudere: la catena DOCKER-USER

VA primordiale · blue team

```
for p in 3100 9090; do
  iptables -I DOCKER-USER -i eth0 -p tcp \
    -m conntrack --ctorigdstport $p --ctdir ORIGINAL \
    ! -s 203.0.113.10 -j DROP
done
```

eth0	l'interfaccia verso Internet (controlla con ip -br a)
203.0.113.10	l'IP pubblico autorizzato, per esempio la scuola
--ctorigdstport	la porta prima che Docker la giri al container

Perché non INPUT: il traffico verso i container passa da FORWARD, e Docker lo manda in DOCKER-USER.

Chi non è nella lista non spedisce più i log: decidete prima chi ci deve stare.

La regola, pezzo per pezzo

VA primordiale · blue team

`-I DOCKER-USER`	inserisce la regola in cima alla catena
`-i eth0`	solo il traffico che entra da Internet
`-p tcp`	solo TCP
`-m conntrack`	usa la tabella delle connessioni del kernel
`--ctorigdstport $p`	la porta chiamata dal client, prima che Docker la cambi
`--ctdir ORIGINAL`	solo i pacchetti di chi apre la connessione, non le risposte
`! -s 203.0.113.10`	! vuol dire "non": sorgente diversa da 203.0.113.10
`-j DROP`	scarta senza rispondere: nmap vedrà filtered

Senza --ctdir ORIGINAL, Alloy sul server non riuscirebbe più a spedire a un Loki esterno sulla 3100.

Più IP ammessi? Non si ripete la regola con il !: la versione giusta è nella lezione 2.

Retest: è davvero chiuso?

VA primordiale · blue team

```
$ nmap -Pn -p 3000,3100,9090 its.fabersoft.net
```

```
PORT      STATE
3000/tcp    open
3100/tcp    filtered
9090/tcp    filtered
```

filtered = nessuna risposta:
il pacchetto è stato scartato.

VA, correzione, retest:
il ciclo, in piccolo.

E da IPv6? Lo vediamo la prossima volta.

Prima di uscire

1. **Che differenza c'è tra VA e PT?**
2. **Cosa deve esserci prima di scansionare una rete?**
3. **Entro quanto si notifica un incidente grave?**

Per la prossima lezione

Lo stesso server, più a fondo: IPv6, regole che sopravvivono al riavvio, Grafana con password vera e TLS.